

Risk Treatment Plan (RTP)

EMSPAKISTAN IT (PRIVATE) LIMITED

1. Purpose

The purpose of this Risk Treatment Plan is to define appropriate actions for managing identified information security risks within EMSPAKISTAN IT (PRIVATE) LIMITED in accordance with ISO/IEC 27001:2022.

2. Scope

This plan applies to all risks identified in the organization's Risk Assessment process, including risks related to IT systems, cloud infrastructure, client data, AI systems, and operational processes.

3. Risk Treatment Strategy

EMSPAKISTAN IT adopts the following risk treatment approaches:

- **Risk Mitigation** – Implement controls to reduce risk
 - **Risk Acceptance** – Accept low-level risks
 - **Risk Transfer** – Transfer risk via third parties (e.g., cloud providers)
 - **Risk Avoidance** – Eliminate risky activities
-

4. Risk Treatment Criteria

Risk treatment decisions are based on:

- Risk Score (Impact × Likelihood)
 - Business impact
 - Legal and compliance requirements
 - Client contractual obligations
 - Cost vs benefit of control implementation
-

5. Risk Treatment Plan

Risk ID	Risk Description	Risk Level	Treatment Strategy	Action Plan	Control Reference	Owner	Timeline
R1	Data Breach (Client Database)	High	Mitigate	Implement MFA, encryption, and access control policies	A.9 Access Control	IT Manager	30 Days
R2	Cloud Misconfiguration	High	Mitigate	Enforce secure configuration baseline and regular audits	A.12 Operations Security	DevOps	20 Days
R3	SQL Injection	High	Mitigate	Implement input validation and secure coding practices	A.14 Secure Development	Dev Team	25 Days
R4	Unauthorized Admin Access	High	Mitigate	Enable MFA and monitor login activity	A.9.4 Access Control	System Admin	15 Days
R5	Malware Infection	High	Mitigate	Deploy antivirus and endpoint protection tools	A.12.2 Malware Protection	IT Support	20 Days
R6	Phishing Attack	High	Mitigate	Conduct security awareness training	A.7 HR Security	HR Manager	30 Days
R7	Data Loss	Medium	Mitigate	Implement automated backup system	A.12 Backup	IT Team	25 Days
R8	Code Theft	High	Mitigate	Restrict repository access and implement logging	A.9 Access Control	Dev Lead	20 Days
R9	Network Intrusion	High	Mitigate	Deploy firewall and intrusion detection systems	A.13 Network Security	IT Team	20 Days
R10	Weak Passwords	High	Mitigate	Enforce strong password policy	A.9 Access Control	Admin	10 Days

R11	AI Data Manipulation	High	Mitigate	Implement integrity checks and monitoring	A.14 System Security	AI Team	25 Days
R12	Data Leakage (Communication)	Medium	Mitigate	Use encrypted communication channels	A.13 Communication Security	Support Team	15 Days
R13	Third-Party Risk	High	Mitigate	Conduct vendor security assessments	A.15 Supplier Security	Management	30 Days
R14	Cloud Storage Exposure	High	Mitigate	Review and fix access permissions	A.8 Asset Management	IT Team	15 Days
R15	Remote Access Risk	High	Mitigate	Implement VPN and secure remote access	A.13 Network Security	IT Team	20 Days

6. Risk Acceptance

Low-level risks may be accepted by management if the cost of mitigation exceeds the benefit. All accepted risks must be formally documented and approved.

7. Monitoring and Review

- Risk treatment progress will be monitored regularly
 - Effectiveness of controls will be reviewed quarterly
 - New risks will be added as identified
-

8. Responsibilities

- **Management** – Approves risk treatment decisions
 - **IT Team** – Implements technical controls
 - **HR Team** – Conducts awareness programs
 - **GRC Function** – Monitors compliance and risk status
-

9. Continuous Improvement

The organization follows a continuous improvement approach to enhance its ISMS through:

- Regular audits
 - Risk reassessment
 - Incident analysis
 - Management review
-

10. Conclusion

This Risk Treatment Plan ensures that all identified risks within EMSPAKISTAN IT (PRIVATE) LIMITED are appropriately managed, reduced, or controlled in alignment with ISO/IEC 27001:2022, supporting the organization's commitment to information security and operational resilience.
